

IR Triage Report

Front Matter

ANALYST NAME: Chibuike Ojukwu

DATE: 08-25-2025

SOURCE: ModSecurity CRS on Apache

ALERT ID: ZgUGhV1CEwAABx43AYAAAAAB

SEVERITY: HIGH ▾

DISPOSITION: True Positive (TP) ▾

Initial Findings

- **Incident type:** Brute-force authentication against WordPress /wp-login.php from **192.168.100.20** using **Mozilla/5.0 (Hydra)**.
- **Scope (confirmed so far):** Traffic between attacker **192.168.100.20** and web server **192.168.100.2** only; four successful logins for user **elliott** (see timeline). No other assets are evidenced in the supplied PCAPs/SIEM sample.
- **Key proof points:**
 - PCAP shows multiple POSTs to /wp-login.php.
 - **Four** server responses are **HTTP/1.0 302 Found** with **Location: /wp-admin/** (success).
 - The **T6b** 302 in attack1.pcap redirects to **/wp-login.php** (not a success) and is **not** counted.

Incident Summary

Time range & duration (UTC)

- **Start:** 2025-04-10 15:42:22.305094 (attack2.pcap, pkt 647, stream 18)
- **End:** 2025-04-10 15:48:41.992074 (attack1.pcap, pkt 10694, stream 595)
- **Duration:** 379.687 seconds (~ 6 min 19.687 s)

Timeline of key events (UTC)

- **15:42:22.305094 – Attack start:** GET /wp-login.php (Hydra UA) begins the first observed 200 OK login-page flow. (attack2.pcap, pkt 647, stream 18)
- **15:42:28.553779 – Successful login #1:** HTTP/1.0 302 Found → **Location: /wp-admin/**. (attack2.pcap, pkt 8446, stream 513)
- **15:42:37.947010 – Successful login #2:** HTTP/1.0 302 Found → **Location: /wp-admin/**. (attack2.pcap, pkt 17040, stream 1082)
- **15:42:47.540769 – Successful login #3:** HTTP/1.0 302 Found → **Location: /wp-admin/**. (attack2.pcap, pkt 25948, stream 1646)
- **15:42:56.170667 – Successful login #4:** HTTP/1.0 302 Found → **Location: /wp-admin/**. (attack2.pcap, pkt 34575, stream 2239)
- **15:48:41.439508 – 302 redirect to /wp-login.php** (not success). (attack1.pcap, pkt 9809, stream 539)
- **15:48:41.992074 – Attack end:** last server **200 OK** to /wp-login.php. (attack1.pcap, pkt 10694, stream 595)

Scope (who/what was involved)

- **Attacker host:** 192.168.100.20
- **Target host / service:** 192.168.100.2 – WordPress login over HTTP/80 (login page HTML references WP assets ver **6.7.2** in earlier 200 OK content)
- **Accounts:**
 - **elliott** – **4 successful authentications** (see above).
 - **admin** – credentials observed in PCAP (Triple10.) but **no successful login** evidenced.
- **Post-login actions: Unknown** (no WP activity logs or Apache access logs post-login were provided).

Impact

- Verified compromise of **one WordPress user account (elliott)** via four successful logins.
- **Credentials exposed in cleartext over HTTP** for elliott and admin during attempts.
- No evidence provided of lateral movement or content/admin changes—**post-login activity not observable** with current artifacts.

SIEM corroboration (Splunk / Zeek)

- Representative Zeek event you supplied (index=client0, source=http.log, sourcetype=zeek_json) confirms POSTs from **192.168.100.20 → 192.168.100.2** to /wp-login.php, status_code=302, user_agent="Mozilla/5.0 (Hydra)".
- **Note:** Zeek http.log typically does **not** record the Location header, so Splunk alone cannot distinguish **success** (302→/wp-admin/) from **non-success** (302→/wp-login.php). We therefore use **PCAP** as ground truth for success.

MITRE ATT&CK

- **T1110.001 – Brute Force: Password Guessing** (repeated POSTs to /wp-login.php)
- **T1071.001 – Application Layer Protocol: Web Protocols** (HTTP over TCP/80)

Recommended Actions

IR / Containment (immediate)

1. **Reset credentials** for **elliott** and **admin**; invalidate active sessions/cookies for elliott.
2. **Force HTTPS** (disable HTTP) on the WordPress site; obtain/enable TLS; add HSTS to prevent credential leakage.
3. **If feasible**, temporarily enable **WAF rate-limiting/IP reputation** and geo/AS throttling for /wp-login.php.
4. **Review post-login behavior:** pull **Apache access/error logs** and any **WP activity/audit logs** from **15:42:28–15:43:30 UTC** to determine actions taken after each successful login.

Prevention (infrastructure)

1. Enforce **account lockout/slowdown** and/or **CAPTCHA** on login after N failed attempts.
2. Require **MFA** for WordPress (at least for editor/admin roles; ideally all users).
3. Ensure WordPress and plugins are current; restrict /xmlrpc.php if not needed.
4. Hide detailed auth errors; ensure no verbose login hints are presented.

Detection / SOC improvements

1. Add correlation in Splunk: **failed attempts** from a source followed by **subsequent 302(s)** to /wp-admin/ within a short window → raise priority.
2. Maintain the Zeek pivot above as a saved search for **Hydra UA** against /wp-login.php.
3. Consider adding **pcap-driven validation** (or reverse proxy logs with Location) to programmatically distinguish success vs. non-success 302s.

Policy / Process

1. Require **TLS-only** for any authentication surface (no exceptions).
2. Document a quick triage SOP for WP brute-force (filters, stream IDs to capture, success criteria = 302→/wp-admin/).

Evidence Appendix (how to re-obtain each key fact)

- **Attack start:**
attack2.pcap → filter tcp.stream == 18 → earliest **GET /wp-login.php** = **pkt 647, 15:42:22.305094 UTC**.
- **Successful logins (4):**
 - **T2b:** attack2.pcap pkt **8446**, stream **513** → HTTP/1.0 302 Found + **Location: /wp-admin/**.
 - **T3b:** attack2.pcap pkt **17040**, stream **1082** → HTTP/1.0 302 Found + **Location: /wp-admin/**.
 - **T4b:** attack2.pcap pkt **25948**, stream **1646** → HTTP/1.0 302 Found + **Location: /wp-admin/**.
 - **T5b:** attack2.pcap pkt **34575**, stream **2239** → HTTP/1.0 302 Found + **Location: /wp-admin/**.
- **Non-success 302 (redirects back to login):**
attack1.pcap pkt **9809**, stream **539** → Location: /wp-login.php.
- **Attack end:**
attack1.pcap → filter http.response.code == 200 → last match **pkt 10694**, stream **595, 15:48:41.992074 UTC**.
- **Credential exposure examples:**
 - attack2.pcap (streams **513/1082/1646/2239**) → POST bodies show log=elliott&pwd=....
 - attack1.pcap stream **539** → POST body shows log=admin&pwd=Triple10. (response 302 → /wp-login.php).